

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for eCommerce

Session : Semester A 2008/09

Time allowed : Two hours

This paper has FIVE pages (including this cover page).

1. This paper consists of 7 questions.
 2. Answer ALL SEVEN questions.
 3. Total: 100 points
 4. This is a close-book examination: students should not bring any book, lecture or tutorial note; problem set solution or any other related paper or printout
 5. Calculators: only HKEA approved ones
-

**NOT TO BE
TAKEN AWAY**

**NOT TO BE
TAKEN AWAY BUT
FORWARD TO LIB**

Remark: Give concise reasons and show key steps in each problem. Keep your answers and reasons brief and right-to-the-point.

1. Symmetric Key Cryptography (24 points)

- (a) (2 points)
What is the size of the key space of shift cipher? Assume that the alphabet contains all alphanumeric letters, that is, from 'a' to 'z' and '0' to '9'.
- (b) (4 points)
Name three security requirements for stream ciphers.
- (c) (4 points)
Give one advantage and two disadvantages of stream ciphers when compared with block ciphers.
- (d) (2 points)
Given one advantage of CTR operation mode over CBC operation mode?
- (e) (2 points)
Describe two problems of using ECB mode. Use at most four sentences to describe the problems. Points will be deducted if more than that are used.
- (f) (4 points)
Draw two diagrams, one to describe decryption in CBC operation mode and the other to describe decryption in CTR operation mode. In each diagram, illustrate how the first two blocks of ciphertexts are decrypted.
- (g) (4 points)
Besides MAC (Message Authentication Code), what is the other type of algorithms which can be used for message authentication? On these two methods for message authentication, what is the advantage of using MAC? Name two concrete algorithms for MAC.
- (h) (2 points)
Among K (a secret key), M (a plaintext) and C (a ciphertext) of a block cipher, indicate what the adversary has already known before launching an attack called "known plaintext attack".

2. Public Key Cryptography (16 points)

(a) (4 points)

List three security requirements of a public key encryption algorithm.

(b) (4 points)

For each of RSA and ElGamal encryption algorithms, name the corresponding number theoretic problem that the security of the algorithm is based on. Also specify in practice, at least how long the RSA public modulus n or the ElGamal prime modulus p should be.

(c) (4 points)

Let $X = -97$. Let Y be the modular inverse of $X \bmod 13$. Find Y and $Y^{58} \bmod 13$. Both of your answers should be positive integers smaller than 13.

(d) (2 points)

If SHA-1 is used, what is the output length of HMAC? Also give one advantage of HMAC over a MAC constructed using AES in CBC mode. Your answer should contain at most three sentences.

(e) (2 points)

List four items that a digital certificate must contain.

3. Authentication and Key Establishment (12 points)

(a) (6 points)

Besides the following challenge-response method for A to authenticate B, describe three other methods which use symmetric key techniques only.

$$A \rightarrow B: N$$

$$A \leftarrow B: E(N, K)$$

where N is a nonce and $E(N, K)$ denotes block cipher encryption of message N under key K , which is pre-shared between A and B.

(b-d) Given the following protocol:

$$A \rightarrow B: \text{"I'm Alice"}, R$$

$$A \leftarrow B: [R, K]_{\text{Bob}}$$

$$A \rightarrow B: [R+1, K]_{\text{Alice}}$$

R and K are nonces. $[X]_{\text{Alice}}$ and $[Y]_{\text{Bob}}$ denote signatures generated by Alice (i.e. A) and Bob (i.e. B), respectively. Answer Yes/No for each of the following three sub-questions. If your answer is no, also give one sentence to explain why.

(b) (2 points)

Can Alice authenticate Bob?

(c) (2 points)

Can Bob authenticate Alice?

(d) (2 points)

Does it support session key establishment?

4. SSL and IPSec (18 points)

(a) (4 points)

When SSL is used for secure web browsing, what are the three security features that SSL is providing?

(b) (4 points)

Name two properties of the IKE Phase 1, Signature Based (Main Mode) that are not supported by the IKE Phase 1, Signature Based (Aggressive Mode).

(c) (2 points)

Among the various versions of IKE Phase 1 (Main Mode), determine which version supports plausible deniability.

(d) (4 points)

Identify what mode(s) of IPSec can be used for each of the following connections.

(1) Host-to-host

(2) Host-to-gateway

(3) Gateway-to-gateway

(e) (4 points)

Give two differences between AH and ESP. The differences should apply for both transport mode and tunnel mode.

5. Computer and Network Security (14 points)

(a) (4 points)

Suppose a 10-character password is chosen where the first five characters have to be chosen from letters 'A' to 'Z' while the remaining five characters have to be chosen from digits '0' to '9'. Determine the size of this password space.

(b) (2 points)

Suppose (s, y) is stored in a password file where s is a salt and $y = h(\text{password}, s)$ is a hash of a password and the salt. If h is changed to MAC where $MAC(M, K)$ is a message authentication code of message M under key K . Determine if the system will remain secure or not. If not, use at most two sentences to explain why.

(c) (4 points)

Construct an Access Control List (ACL) such that the packet filter only allows company employees to access secure/insecure web servers on the Internet and SSH (secure shell) hosts within the company network. The port numbers of SSL and HTTP are 443 and 80, respectively and that of SSH is 22.

(d) (2 points)

If the number of hops between the adversary's machine and a stateful packet filter is 1. What value of TTL should the adversary set for launching Firewalk.

(e) (2 points)

Give one difference between worm and bacteria.

6. Email Security (6 points)

(a) (2 points)

If the original message is 123 bytes long, how many characters are required for representing the message after encoding it using base64?

(b) (4 points)

In PGP, what are the three cases where a public key in one's public key ring is considered legitimate?

7. Wireless Security (10 points)

(a) (2 points)

In GSM authentication, identify which of the following parties could know the user key K_i .

- (1) User's SIM card
- (2) AuC (Authentication Center)
- (3) Base station
- (4) Base station controller

(b) (2 points)

In GSM authentication, SRES is only 32 bits long while RAND is 128 bits long. What is the probability that an online active adversary is able to guess the value of SRES correctly?

(c) (4 points)

Name three security objectives that are common to both GSM and 3GPP.

(d) (2 points)

Name the algorithm that is used in WEP for message authentication? What is the effective key length of WEP?

- End -